

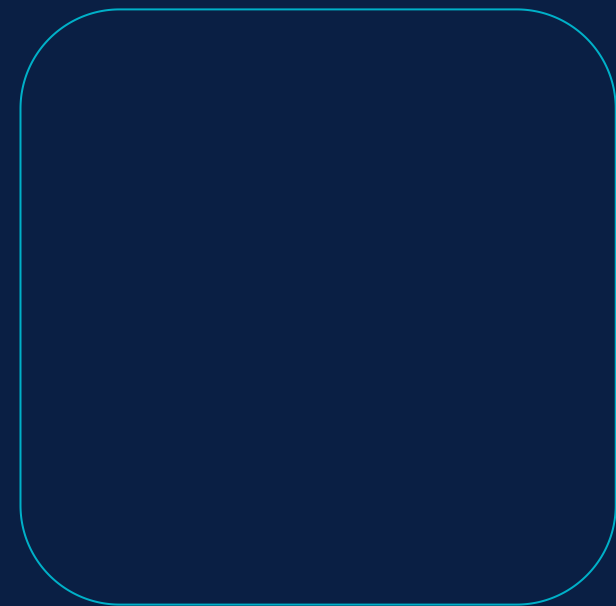
无线网络安全专题汇报

Zigbee 协议安全剖析

—— 当你的智能灯泡成为黑客的入口

汇报人：沈文强

课程：无线网络安全



本次汇报将围绕以下五个部分展开

01

走近 Zigbee

为什么这种「小协议」值得我们关注

02

Zigbee 安全机制

AES-128、信任中心与密钥体系

03

六大攻击面

从空中到芯片，威胁全景图

04

三个真实案例

蠕虫、智能锁与窃密木马

05

防护建议与启示

厂商 · 用户 · 研究者三视角

全球已有数十亿台设备在用，但它真的安全吗？

| 什么是 Zigbee？

- ▶ 基于 IEEE 802.15.4 的无线个域网协议
- ▶ 工作频段 2.4 GHz（全球通用）
- ▶ 速率 250 kbps，传输距离 10–100 m
- ▶ 支持 Mesh 自组网，单网最多 65535 节点
- ▶ 低功耗：纽扣电池可工作数年
- ▶ 广泛用于智能家居、楼宇自控、医疗

| Zigbee 协议栈四层结构

APL 应用层	应用框架 / Zigbee Cluster Library
NWK 网络层	路由、入网、组网（Zigbee 自定义）
MAC 介质访问	IEEE 802.15.4
PHY 物理层	IEEE 802.15.4（2.4GHz）

| 你身边的 Zigbee

- ▶ 小米米家 / Aqara 网关与子设备
- ▶ Amazon Echo Plus（内置 Zigbee 网关）
- ▶ Philips Hue 智能灯泡（标志性产品）
- ▶ IKEA Trådfri 智能照明系列
- ▶ Samsung SmartThings、华为智选生态

看似严密的密码学防线

Zigbee 安全的三大支柱：三层密钥体系



核心算法：AES-128-CCM（机密性 + 完整性 + 重放保护）



⚠ 但是——再强的密码学，也抵不过一次「明文传输」的疏忽.....

Zigbee 安全威胁全景图

01 入网密钥明文传输

默认 TC 链路密钥 'ZigBeeAlliance09' 公开!
配对瞬间被嗅探即可解密整网

02 重放与注入攻击

未启用 **Frame Counter** 校验的旧设备
可被重放开锁/开关指令

03 无线干扰与拒绝服务

2.4GHz 频段拥挤
Reactive Jamming 可瘫痪整网

04 Sybil / Rogue 路由

伪造大量节点 / 假冒协调器
劫持 **Mesh** 路由表

05 固件与侧信道

JTAG / SPI 调试口未关闭
可直接读出 **AES** 密钥

06 跨协议桥接攻击

通过 **Zigbee** 横向跳到 **Wi-Fi** / 蓝牙
实现内网渗透

2017 · 以色列魏茨曼研究所 & 加拿大达尔豪斯大学

攻击场景与原理

攻击目标	飞利浦 Hue 智能灯泡（ZLL 协议）
漏洞根源	ZLL Touchlink 入网时使用固定主密钥，且未严格校验距离
攻击载具	无人机/汽车搭载 ATmega2564RFR2 + 改装天线，从数百米外发动
传播方式	感染一只灯泡 → 强制其重置 → 加入攻击者网络 → 推送恶意固件 → 继续感染相邻灯泡，形成蠕虫式扩散
可造成的后果	1. 城市级灯光全部闪烁，诱发癫痫患者发作 2. 灯光按特定频率闪烁，作为隐蔽信道泄露数据 3. 利用灯泡的电力线噪声攻击周边设备

✦实验测算威力

巴黎全市

仅需 15,000 只被感染灯泡

整网蠕虫扩散时间

< 几分钟（指数级传播）

给我们的启示

- ▶ 物联网「低功耗」≠ 低风险
- ▶ 单点漏洞 + Mesh 网络 = 蠕虫级灾难
- ▶ 厂商的「出厂默认值」是最大的安全盲区
- ▶ 智能家居正在成为关键基础设施

Black Hat USA · 多次披露 · 国内某品牌锁同类漏洞

攻击四步走

1

嗅探入网

攻击者携带 KillerBee + Wireshark 蹲守在用户门外，等待新设备入网

2

截获密钥

捕获 Transport-Key 命令 获得明文传输的网络密钥

3

解密流量

解密后续所有上下行报文 包括开锁/关锁指令与状态

4

伪造指令

重放或伪造合法开锁报文 门锁无识别能力，直接打开

\$ KillerBee Zigbee 抓包终端

zbid	CH	Source	Dest	Cmd
00:01	15	0x00:158d0001a2f3b	broadcast	Beacon
00:02	15	Coord	0x00:158d0001a2f3b	TC_Link
00:02	15	Coord → node	[Transport-Key]	⚠ PLAIN
00:03	15	node	Coord	Confirm
00:08	15	Coord	Lock	UnlockReq
00:08	15	Lock	Coord	UnlockACK ✓

>>> Captured NWK key: 5A 69 67 42 65 65 41 6C ...
>>> Replaying UnlockReq with valid MIC ... DOOR OPENED ✗

⚠ 现实警示

- ▶ 全套设备成本 < 300 元
- ▶ 攻击时长 < 30 秒（无需用户感知）
- ▶ 国内多款「智能门锁」曾被 CNVD 通报
- ▶ 受害者：往往直到被入室盗窃才察觉

2018 · Amazon Echo / SmartThings 网关的 Zigbee 侧门

一次「由灯泡入侵到家庭路由器」的完整攻击链



攻击关键点

- ▶ 降级攻击：迫使节点回退到弱密钥模式
- ▶ 利用 Zigbee 网关与 Wi-Fi 共享芯片组的内存
- ▶ 通过精心构造的 Zigbee 帧触发缓冲区溢出
- ▶ 在 Wi-Fi 协议栈中执行任意代码
- ▶ 无需用户任何操作，全程零交互

💡 这意味着什么？

家中「最便宜」的设备，
可能是整张内网最脆弱的入口

攻击者关心的从来不是灯泡，
而是灯泡背后的整个数字生活

厂商 · 用户 · 研究者，三视角共筑防线

厂商侧

- ▶ 禁用默认 TC 链路密钥
- ▶ 强制 Install Code 入网（每台唯一）
- ▶ 升级至 Zigbee 3.0 / R23
- ▶ 固件签名 + 安全启动
- ▶ 关闭量产 JTAG / SPI 调试口
- ▶ 提供长期 OTA 升级通道

用户侧

- ▶ 采购选择 Zigbee 3.0 认证设备
- ▶ 首次配网避开公共场所
- ▶ 网关与家庭路由器隔离 VLAN
- ▶ 定期检查并更新设备固件
- ▶ 弃用 EOL 老设备（如 ZHA 1.0）
- ▶ 重要场景配合物理钥匙

研究者侧

- ▶ 开放协议栈模糊测试工具
- ▶ 推动 Install Code 标准化
- ▶ 完善 IoT 安全测评体系（GB/T）
- ▶ 建立设备 SBOM 与漏洞通报机制
- ▶ 跨协议安全联合分析
- ▶ 把「安全」纳入物联网课程必修

从一只灯泡看见整个物联网的明天

三句话总结今天的汇报

①

Zigbee 并不弱，弱的是「出厂默认」——
标准明文密钥让所有加密形同虚设。

②

物联网的攻击面 = 设备数 × 协议数 × 接口数，
任何一只灯泡都可能是攻陷家庭的钥匙。

③

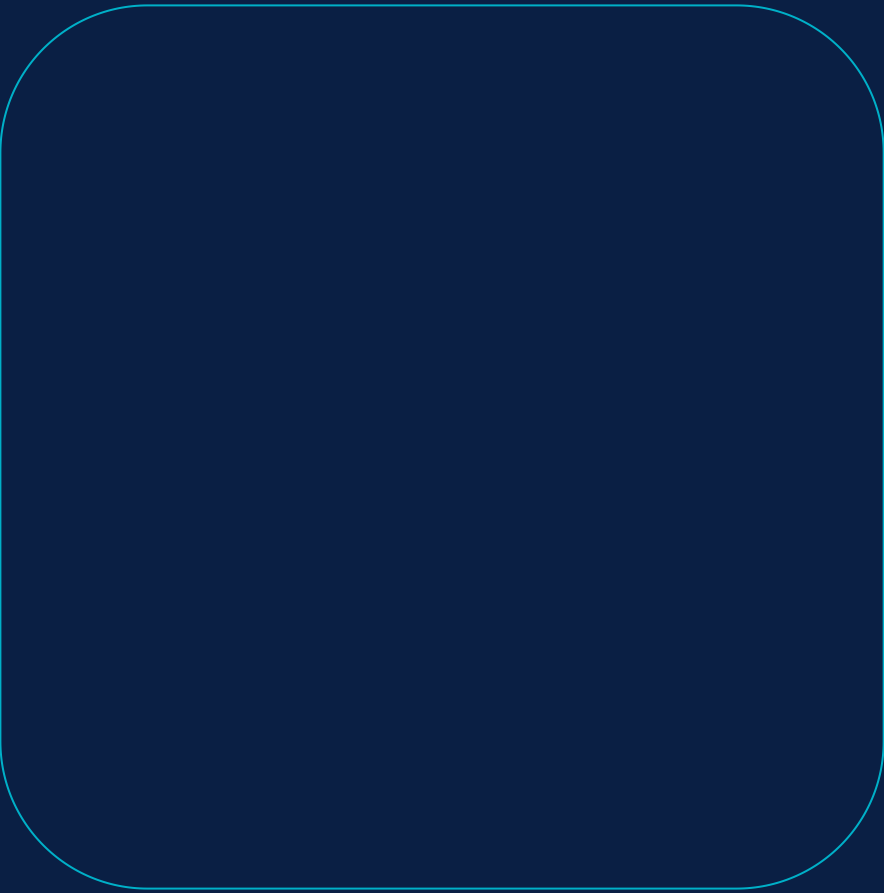
安全不是产品的附加功能，而是物联网的呼吸——
停止呼吸的那一刻，所有「智能」都会变成隐患。

🚀 行业趋势：Matter / Thread 时代

- ▶ Matter（CSA 联盟）：统一 IPv6 over Thread
- ▶ Thread：与 Zigbee 同源（IEEE 802.15.4）
- ▶ DTLS + 证书：从根本上消灭「默认密钥」
- ▶ 但旧 **Zigbee** 设备仍将存活数年至十数年

“

我们把房子装满了“会思考”的灯泡、
插座、门锁——
却很少思考它们正在思考什么。



Thanks

感谢聆听
